IT AUDIT & OBSERVATION

Note: This is a portfolio project. The company, personnel, and log data are fictional and synthetic.

TO: Chief Information Security Officer (CISO), VortexPe Solutions.
FROM: Shobana N, GRC Analyst (Portfolio Project)
DATE: September 2026
SUBJECT: Q3 2026 Production Database ITGC Access Control Audit (Simulated)
STANDARD: ISO 27001:2022 (Annex A.5.3, A.5.17, A.8.2, A.8.5, A.8.15) | ITGC Access Management

1. EXECUTIVE SUMMARY

During the simulated Q3 2026 IT General Controls (ITGC) review, production database access logs were analyzed for VortexPe Solutions. The objective was to evaluate user access controls, privilege management, and logging practices against ISO 27001:2022.

The review identified three high-risk control weaknesses: excessive developer privileges in production (with a related Segregation of Duties concern), an apparently unapproved privilege grant, and the use of a shared administrative account accessed from an untrusted external IP address outside business hours. Prompt remediation is recommended to reduce the risk of data loss, unauthorized system changes, and loss of accountability.

2. AUDIT SCOPE & METHODOLOGY

• **Audit Scope:** Simulated production database audit logs (Log IDs 101-107, 1-2 August 2026).
• **Frameworks Evaluated:** ISO 27001:2022 Controls A.5.3 (Segregation of Duties), A.5.17 (Authentication Information), A.8.2 (Privileged Access Rights), A.8.5 (Secure Authentication), A.8.15 (Logging), and ITGC Access Management practices.
• **Audit Procedure:** Four SQL test queries were run on the mock dataset to detect developer DDL activity, privilege grants, off-hours or untrusted-IP access, and repeated failed logins.
• **Limitations:** The dataset is synthetic and small. No ticketing or approval records were available, so approval status could be flagged for follow-up but not confirmed.

3. DETAILED AUDIT FINDINGS (CCCER FRAMEWORK)

FINDING 1: Excessive Developer Privileges in Production

- **Risk Level: HIGH**
- **Condition:** Log ID 103 shows that developer account 'dev_john' successfully executed a Data Definition Language (DDL) command ('DROP TABLE payment_logs') in the production environment.
- **Criteria:** ISO 27001:2022 Controls A.8.2 (Privileged Access Rights) and A.5.3 (Segregation of Duties) require that privileged production access, such as schema changes, is restricted to authorized roles and separated from development duties.
- **Cause (likely, to be confirmed with management):** The developer account held ALL PRIVILEGES in production (see Finding 2), indicating that RBAC restrictions on developer roles were absent or not enforced.
- **Effect:** Accidental or malicious deletion of production data, operational downtime, and potential regulatory or audit consequences.
- **Recommendation:** Revoke direct DDL rights from developer accounts in production. Implement Just-In-Time (JIT) administrative access with manager approval and enforce RBAC.

[EXHIBIT 1: SQL Audit Query Output - Developer DDL Activity in Production]

```sql
SELECT log_id, timestamp, db_user, user_role, client_ip, action_performed
FROM db_audit_logs
WHERE user_role = 'Developer'
  AND (
       action_performed LIKE '%DROP%'
    OR action_performed LIKE '%ALTER%'
    OR action_performed LIKE '%GRANT%'
  );
```

Audit query output showing DDL execution by a developer role (Log ID 103) :

Query #1 **Execution time: 0.31ms**

log_id	timestamp	db_user	user_role	client_ip	action_performed
103	2026-08-01 11:00:00	dev_john	Developer	192.168.1.45	DROP TABLE payment_logs

FINDING 2: Unapproved Privilege Escalation

- **Risk Level: HIGH**
- **Condition:** Log ID 102 shows DBA account 'admin_sarah' granting ALL PRIVILEGES to 'dev_john' on 1 August 2026 at 10:30, about 30 minutes before the table was dropped (Log ID 103). No evidence of approval was available in the logs provided; the grant should be traced to an approved change request.
- **Criteria:** The ITGC Access Control Policy and ISO 27001:2022 Control A.8.2 require privileges to be granted on a least-privilege basis, for a documented business need, and with formal authorization.
- **Cause (likely, to be confirmed with management):** No enforced workflow links database privilege grants to approved change requests (e.g., Jira/ServiceNow).
- **Effect:** Over-privileged accounts increase the potential damage from insider threats or compromised developer credentials, and a single administrator can grant powerful access without independent review.
- **Recommendation:** Trace this grant to a change request and document the outcome. Implement automated alerts on GRANT ALL PRIVILEGES commands, and require approval before privileged grants are executed.

[EXHIBIT 2: SQL Audit Query - Privilege Grants]

```
SELECT log_id, timestamp, db_user, action_performed, client_ip
FROM db_audit_logs
WHERE action_performed LIKE '%GRANT%';
```

Audit query output showing 'admin_sarah' granting ALL PRIVILEGES to 'dev_john':

Query #2 **Execution time: 0.3ms**

log_id	timestamp	db_user	action_performed	client_ip
102	2026-08-01 10:30:00	admin_sarah	GRANT ALL PRIVILEGES TO dev_john	10.0.0.12

FINDING 3: Shared Administrative Accounts & Anomalous Off-Hours Access

- **Risk Level: HIGH**
- **Condition:** Log ID 104 shows the shared account 'shared_admin' running SELECT * FROM credit_cards at 02:15 AM on 2 August 2026 from an untrusted public IP address (185.220.101.5). Within about 70 seconds, Log IDs 105-107 show three consecutive failed login attempts from the same IP address.
- **Criteria:** ISO 27001:2022 Controls A.5.17 (Authentication Information), A.8.5 (Secure Authentication), and A.8.15 (Logging) require individually attributable accounts, strong authentication, and logs that support accountability. ITGC Access Policy expects administrative access to originate from trusted network paths (e.g., VPN or bastion host).
- **Cause (likely, to be confirmed with management):** A legacy generic administrative login remains in use without MFA or IP allow-listing.
- **Effect:** Actions cannot be attributed to an individual during incident response, and sensitive cardholder data is exposed to brute-force or credential-theft attacks.
- **Recommendation:** Treat Log ID 104 as a potential security incident and review it, including rotating the shared credential. Retire shared accounts, enforce individual named DBA accounts with MFA, and restrict administrative access to a bastion host or VPN.

[EXHIBIT 3: SQL Audit Queries - Anomalous Access and Repeated Failed Logins]

```sql
-- Query 3
SELECT log_id, timestamp, db_user, user_role, client_ip, action_performed
FROM db_audit_logs
WHERE (
        EXTRACT(HOUR FROM timestamp) NOT BETWEEN 8 AND 19
     OR (client_ip NOT LIKE '192.168.%' AND client_ip NOT LIKE '10.0.%')
);

-- Query 4
SELECT db_user, client_ip, COUNT(*) AS failed_login_count
FROM db_audit_logs
WHERE status = 'FAILURE'
GROUP BY db_user, client_ip
HAVING COUNT(*) >= 3;
```

Query output showing off-hours or external-IP activity and repeated authentication failures for 'shared_admin':

Query #1 Execution time: 0.41ms

log_id	timestamp	db_user	user_role	client_ip	action_performed
104	2026-08-02 02:15:00	shared_admin	DBA	185.220.101.5	SELECT * FROM credit_cards
105	2026-08-02 02:16:00	shared_admin	DBA	185.220.101.5	FAILED LOGIN ATTEMPT
106	2026-08-02 02:16:05	shared_admin	DBA	185.220.101.5	FAILED LOGIN ATTEMPT
107	2026-08-02 02:16:10	shared_admin	DBA	185.220.101.5	FAILED LOGIN ATTEMPT

Query #2 Execution time: 0.26ms

db_user	client_ip	failed_login_count
shared_admin	185.220.101.5	3

4. MANAGEMENT REMEDIATION ACTION PLAN

Finding	Action Item	Owner	Priority	Target due date
1	Revoke Dev DDL Rights & Enforce RBAC	DBA Lead / SecOps	High	15 days
3	Review Log ID 104 as a potential incident; rotate credentials	SecOps	High	7 days
3	Deprecate Shared Accounts & Add MFA	IAM / SecOps Team	High	30 days
2	Trace the ALL PRIVILEGES grant to an approved change request	DBA Lead / Change Mgmt	High	15 days
2	Configure SIEM Alerts for GRANTs	SOC Team	Medium	45 days
1, 2	Establish Quarterly Access Review	IAM Lead / Dept. Managers	Medium	Next audit cycle

Internal Audit will follow up on the status of these actions during the next review cycle.